

SEGURIDAD · IDENTIDAD · CONFIANZA



Guardián Monarca

Sistema de Gestión Segura de Identidades para Casa Monarca

Doble factor + RBAC + auditoría protegen la información de las personas migrantes.

Guardián Monarca es una plataforma web propia que combina autenticación con certificado digital X.509, control de acceso por roles y un registro inmutable de cada acción crítica. El resultado: sólo el personal autorizado, desde el dispositivo correcto, puede acceder a los expedientes de personas migrantes.



Los procesos actuales dejan expedientes vulnerables; una PKI propia los blindo.



EL PROBLEMA HOY

- Acceso sin autenticación fuerte: una contraseña basta para entrar desde cualquier dispositivo.
- Sin trazabilidad: no hay registro de quién modificó o eliminó un expediente.
- Roles sin fronteras técnicas: un operativo puede ver todo igual que un administrador.
- Certificados manuales o inexistentes: sin revocación formal ante la salida de personal.
- Datos de migrantes vulnerables a accesos indebidos o fuga de información.



LA OPORTUNIDAD

- PKI propia: Casa Monarca emite y revoca sus certificados X.509.
- Doble factor real: contraseña + archivo .p12 en USB = dos capas independientes.
- RBAC estricto: Admin, Coordinador, Operativo y Voluntario con permisos diferenciados.
- Auditoría permanente: cada login, cambio de rol y movimiento de datos queda registrado.
- Proceso de baja segura: eliminaciones requieren aprobación formal del administrador.

Cinco capas validan al usuario antes de mostrar un solo expediente.



Sin certificado físico ningún rol de administración puede iniciar sesión — aunque conozcan la contraseña.

Cuatro objetivos SMART definen el éxito de Guardián Monarca.

O1 Eliminar el acceso no autorizado

Implementar doble factor (contraseña + certificado X.509) para roles de alto privilegio, reduciendo a cero la posibilidad de acceso solo con contraseña comprometida.

O2 Gestionar identidades con trazabilidad

Registrar el 100% de los eventos de autenticación, cambios de rol y emisión/revocación de certificados en un log inmutable con IP y timestamp.

O3 Proteger datos de personas migrantes

Restringir el acceso a expedientes según rol: Voluntarios registran, Operativos ven y registran, Coordinadores editan, Admins tienen control total con aprobación.

O4 Establecer proceso seguro de altas y bajas

Automatizar la emisión de certificados .p12 al dar de alta personal y la revocación inmediata en base de datos al momento de la baja.

Cuatro perfiles con distinto nivel de acceso al sistema.

ROL	PERFIL	ACCESO	PRINCIPALES CAPACIDADES	
01	Administrador <i>Coordinador general · responsable de TI</i>	Doble factor + USB	▶ Gestiona todos los expedientes ▶ Aprueba resets y eliminaciones	▶ Emite y revoca certificados .p12 ▶ Ver log y métricas completos
02	Coordinador <i>Coordinación operativa · supervisa trabajo de campo</i>	Doble factor + USB	▶ Ver y editar todos los expedientes ▶ Solicitar eliminación	▶ Registrar con folio y documentos ▶ Ver certificados vigentes
03	Operador <i>Personal de campo · primer contacto con migrantes</i>	1FA + cert validado en BD	▶ Ver expedientes registrados ▶ Subir documentos	▶ Registrar nuevos expedientes ▶ Ver su propio certificado
04	Voluntario <i>Apoyo puntual externo · acceso restringido</i>	Sólo contraseña	▶ Registrar expedientes (captura)	▶ Ver su panel personal básico

Cinco escenarios críticos cubiertos por procedimientos formales.

CASO 01  Cambio de Administrador Activar Admin de Respaldo · emitir .p12 al nuevo admin · revocar cert saliente · desactivar cuenta. Script bootstrap como llave maestra protegida físicamente.	CASO 02  Pérdida o robo de USB Revocación instantánea desde panel · al presentar el .p12 el sistema devuelve 403 antes de cargar página · se emite nuevo cert y se entrega en mano.	CASO 03  Olvido de contraseña Usuario solicita reset desde login · Admin recibe la solicitud · al aprobar se genera contraseña temporal · se comunica por canal externo seguro · queda en log.	CASO 04  Baja de personal Admin revoca cert · desactiva cuenta · registros y log se conservan para trazabilidad histórica · eliminación final disponible sólo si la cuenta está desactivada.	CASO 05  Certificado expirado Sistema marca como expirado al pasar fecha · usuario recibe aviso al intentar entrar · Admin emite nuevo .p12 · anterior queda en historial.
--	---	---	---	---

FLUJO DE ALTA

Cinco pasos garantizan que cada voluntario accede sólo con las credenciales correctas.

01

Admin registra al voluntario

Desde el panel crea la cuenta, asigna el rol y genera las credenciales de forma automática.

02

Sistema genera credenciales según el rol

Admin · Coordinador

.p12 + cert público + README + contraseña temporal

Operador · Voluntario

Solo contraseña temporal

03

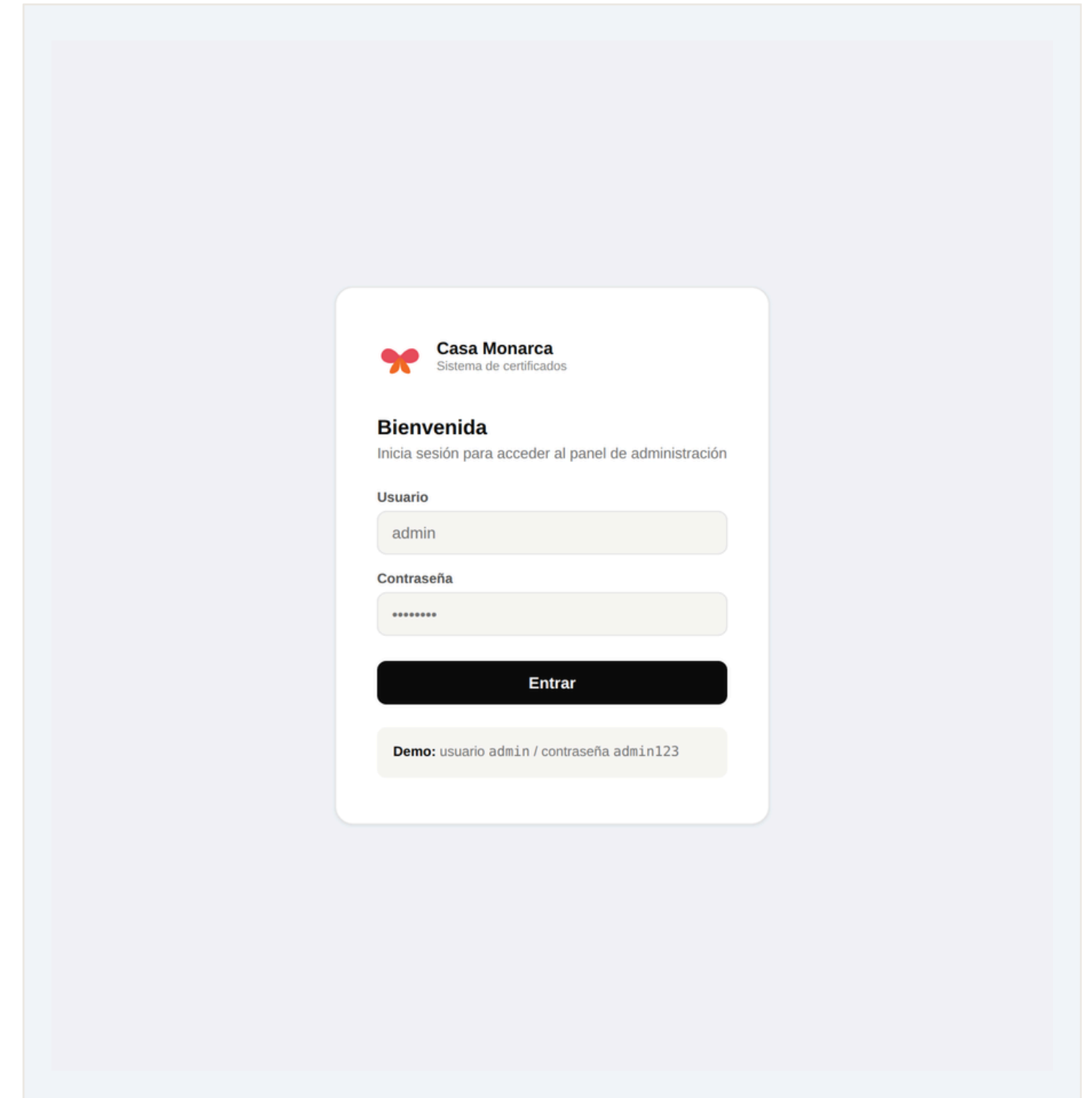
Voluntario inicia sesión con sus credenciales

El sistema valida el certificado (cuando aplica) y la contraseña antes de conceder acceso.

04

Cambia su contraseña temporal en primer acceso

El sistema lo obliga a establecer una contraseña personal antes de mostrar cualquier dato.



Vista de la pantalla de acceso

Qué puede hacer cada rol — vista comparativa.

ACCIÓN / CAPACIDAD	ADMIN	COORDINADOR	OPERADOR	VOLUNTARIO
Iniciar sesión con doble factor (.p12)	●	●	—	—
Ver expedientes de migrantes	●	●	●	—
Registrar nuevos expedientes	●	●	●	●
Editar expedientes existentes	●	●	—	—
Eliminar expedientes	●	◐	—	—
Emitir / revocar certificados .p12	●	—	—	—
Gestionar usuarios y resets de contraseña	●	—	—	—
Ver log de auditoría y métricas	●	—	—	—
Cambiar el rol de un usuario	●	—	—	—

● Permitido ◐ Requiere aprobación — No permitido

Tecnología estándar de industria



SEGURIDAD · PKI

- X.509 & RSA-2048/4096
- PKCS#12 (.p12) con AES
- Autoridad Certificadora propia
- SHA-256 para firma digital



BACKEND

- Python 3 + Flask
- MySQL
- Werkzeug · bcrypt
- Flask-Session (filesystem)



FRONTEND

- HTML5 + CSS3 responsive
- JavaScript (fetch API)
- Templates Jinja2
- Admin dashboard dinámico



INFRA

- MySQL 8 (producción)
- SQLite (desarrollo)
- TLS HTTPS en localhost
- Conexión por USB simulada

Seis algoritmos protegen cada capa del sistema.

RSA-4096

Autoridad Certificadora

Genera el par de claves de la CA raíz. La clave privada nunca sale del servidor. Firma todos los certificados X.509 del sistema.

EC P-256

Claves de usuario

Cada colaborador tiene un par de claves elípticas P-256 almacenado en su archivo .p12. Clave pública en la BD, privada en USB.

ECDSA P-256 + SHA-256

Firmas digitales

Firma cada operación crítica: registro de migrante, aprobaciones ARCO, cadena de custodia. 512 bits vs 3072 bits de RSA.

AES-256 (PKCS#12)

Archivos .p12

Protege la clave privada del usuario en el archivo USB. Sin la contraseña correcta el .p12 es ilegible.

PBKDF2-HMAC + bcrypt

Contraseñas

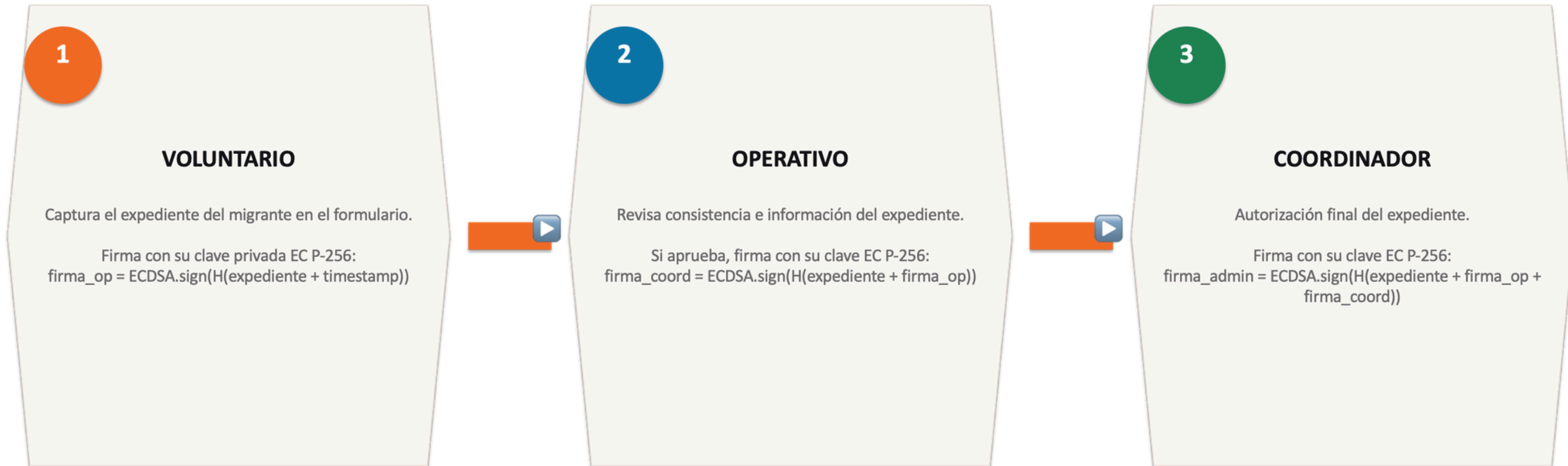
Derivación y almacenamiento seguro. bcrypt con salt único por usuario. PBKDF2-HMAC-SHA256 para claves de sesión.

HMAC-SHA256

Sesiones Flask

Flask-Session firma criptográficamente cada cookie de sesión con SESSION_USE_SIGNER. Sin firma = sesión rechazada.

Tres firmas ECDSA P-256 garantizan que ningún actor puede actuar unilateralmente.



MySQL · solicitudes_registro_migrante

campos: firma_op · pubkey_op · firma_coord · pubkey_coord · firma_admin · pubkey_admin · mensaje_firmado_op · mensaje_firmado_coord · mensaje_firmado_admin

Cuatro derechos — un flujo jerárquico con firma digital en cada paso.

A

ACCESO

Operativo (CR)

El migrante solicita ver sus datos.
El Operativo busca el expediente y presenta la información en pantalla.
Se registra el evento en el log de auditoría con timestamp, IP y usuario.

R

RECTIFICACIÓN

Operativo solicita → Coordinador aprueba

Operativo registra los cambios solicitados (solicitudes_arco_rect).
Coordinador revisa y aprueba o rechaza.
Si se aprueba: cambios aplicados en expediente + log 'arco_rect_aprobada'.

C

CANCELACIÓN

Coordinador firma ECDSA → Admin ejecuta

Coordinador firma criptográficamente la solicitud con EC P-256.
Admin verifica la firma y ejecuta la eliminación física.
Historial_eliminaciones conserva folio + quién solicitó + quién ejecutó.

O

OPOSICIÓN

Mismo flujo que Cancelación

El migrante puede oponerse al uso de sus datos para fines específicos.
Suspensión del uso mientras se resuelve la petición.
Admin documenta la resolución y la registra en log inmutable.

Cuatro resultados tangibles para Casa Monarca desde el día uno.

0

accesos no autorizados
posibles sin certificado físico

100%

acciones críticas
registradas en el log de auditoría

4

roles diferenciados
con permisos estrictos desde día uno



Seguridad real en datos de migrantes

Información personal protegida con criptografía estándar industria (X.509/RSA), no sólo contraseñas.



Velocidad operativa sin fricciones

Alta de personal en minutos: el .p12 se genera, descarga y entrega desde el mismo panel.



Cumplimiento y rendición de cuentas

Cada acción firmada digitalmente. El log identifica quién, cuándo y desde qué IP actuó.



Escalable desde el día uno

Diseñado con MySQL para producción. Agregar usuarios o sucursales no requiere cambios de arquitectura.

Gracias.



Casa Monarca merece la mejor protección para quienes más lo necesitan.

EQUIPO

Paola · Steffany · Patricio · Santiago · María Paula · Andrés

Enlaces Presentaciones



Hipervínculos:

Presentación 1

Presentación 2

EQUIPO

Paola · Steffany · Patricio · Santiago · María Paula · Andrés